



الجامعة السورية الخاصة

كلية هندسة الذكاء الاصطناعي

هندسة امن النظم والشبكات الحاسوبية الذكية

تطوير نظام منع تسرب بيانات قائم على الويب في الشبكات المحلية

إعداد

سعود عبد العزيز الحجي

إشراف

د. وسيم جنيدي

نيسان - 2026

جدول المحتويات

4	جدول الجداول
4	جدول الاشكال
5	الفصل الأول
6	1.1 مقدمة
6	1.2 المشكلة الرئيسية
7	1.3 هدف المشروع
8	1.4 النظام المقترح
9	1.5 تنظيم التقرير
9	1.6 خاتمة المقدمة
10	الفصل الثاني
11	2.1 المقدمة
11	2.2 ما هو مفهوم DLP
11	2.3 كيف يعمل DLP
12	2.3.1 المراحل الأساسية لعمل نظام DLP
12	2.3.2 المرحلة الأولى - الاكتشاف (Discovery)
13	2.3.3 المرحلة الثانية - التصنيف (Classification)
14	2.3.4 المرحلة الثالثة - وضع السياسات (Policy Definition)
15	2.3.5 المرحلة الرابعة - المراقبة (Monitoring)
16	2.3.6 المرحلة الخامسة - التحليل (Analysis)
17	2.3.7 المرحلة السادسة - الاستجابة (Response)
17	2.4 أنواع DLP (Data Leakage Prevention Types)
17	2.4.1 التصنيف حسب موقع النشر (Deployment-Based Classification)
23	2.4.2 التصنيف حسب طريقة الحماية (Protection Approach-Based Classification)

23	2.4.3 التصنيف حسب حالة البيانات (Data State-Based Classification)
23	2.4.4 التصنيف حسب المصدر (Vendor-Based Classification)
24	2.4.5 جدول مقارنة شامل لأنواع DLP
24	2.4.6 نموذج النشر المتكامل (Integrated Deployment Model)
26	2.4.7 معايير اختيار النوع المناسب من DLP
26	2.5 ما هو DLP System
26	2.6 كيف يعمل DLP بالتفصيل حسب بيئة النشر
26	2.6.1 على الخوادم (Servers)
27	2.6.2 على المتصفحات (Browsers)
27	2.6.3 على طرفيات الموظفين (Endpoints)
27	2.7 التقاط وتحليل حركة المرور الداخلية
27	2.8 فحص المحتوى العميق (Deep Content Inspection)
28	2.9 إعادة بناء وتتبع الجلسات (Session Reconstruction & Tracking)
28	2.10 آليات الإنذار والاستجابة الفورية
28	2.11 تصنيف البيانات (Data Classification)
29	2.12 تطبيق السياسات (Policy Enforcement)
29	2.13 أحدث ما توصلت إليه التكنولوجيا State of the Art
31	2.14 الدراسات المرجعية (Reference Studies)
32	2.15 الخلاصة

جدول الجداول

12	جدول 1 : المراحل الأساسية لعمل نظام DLP
13	جدول 2 : تصنيف آليات الاكتشاف
14	جدول 3 : مستويات التصنيف النموذجية
17	جدول 4 : آليات الاستجابة
18	جدول 5 : مزايا DLP على مستوى الشبكة
19	جدول 6 : التحديات التي تواجه DLP على مستوى الشبكة
20	جدول 7 : مكونات المراقبة على Endpoint
20	جدول 8 : مزايا مكونات المراقبة على Endpoint
21	جدول 9 : التحديات التي تواجه مكونات المراقبة على Endpoint
21	جدول 10 : أنواع Cloud DLP
22	جدول 11 : مزايا CASB
22	جدول 12 : عيوب CASB
23	جدول 13 : أنواع طرق الحماية
23	جدول 14 : أنواع البيانات التي يتعامل معها DLP
24	جدول 15 : تصنيف حلول DLP حسب طبيعة المصدر
24	جدول 16 : مقارنة عامة بين أنواع DLP
26	جدول 17 : عوامل اختيار DLP
31	جدول 18 : State of the Art
32	جدول 19 : الدراسات المرجعية

جدول الاشكال

11	رسم توضيحي 1 : نظام منع تسريب بيانات عام
13	رسم توضيحي 2 : أنواع التصنيف في DLP
18	رسم توضيحي 3 : أنواع DLP حسب موقع النشر
19	رسم توضيحي 4 : DLP Endpoint على مستوى نقاط النهاية
22	رسم توضيحي 5 : آلية العمل عبر CASB
25	رسم توضيحي 6 : الهيكلية العامة لنظام DLP
29	رسم توضيحي 7 : أعلى أنواع DLP في السوق حسب التسعير

الفصل الأول

مقدمة

1.1 مقدمة

في عصر التحول الرقمي المتسارع، أصبحت البيانات تمثل المورد الاستراتيجي الأكثر قيمة للمؤسسات، حيث تشكل العمود الفقري لعملياتها وقراراتها التنافسية. ومع هذا الاعتماد المتزايد على البنى التحتية الرقمية، تتصاعد حدة المخاطر الأمنية المرتبطة بسلامة هذه البيانات وسريتها، لا سيما في بيئات الشبكات المحلية (LAN) التي تشكل القلب النابض لأي مؤسسة. في هذا السياق، تبرز أنظمة منع فقدان البيانات (Data Leakage Prevention - DLP) كأحدى الركائز الأساسية في استراتيجيات الأمن السيبراني الحديثة، حيث تمثل خط دفاع متقدمًا يهدف إلى ضمان عدم خروج المعلومات الحساسة من حدود الشبكة الداخلية، سواء كان ذلك مقصودًا من قبل مستخدم خبيث أو ناتجًا عن خطأ بشري غير مقصود. إن الحماية التقليدية القائمة على جدران الحماية وأنظمة كشف التسلل (IDS) لم تعد كافية وحدها لمواجهة التحديات المعاصرة، إذ تركز هذه الأنظمة غالبًا على التهديدات القادمة من خارج الشبكة، بينما تغفل عن مخاطر التسرب الداخلي للبيانات التي قد تحدث عبر قنوات الاتصال بين الأجهزة داخل الشبكة المحلية ذاتها. هذا الفراغ الأمني يخلق فجوة خطيرة، حيث يمكن للمعلومات الحساسة أن تُنقل عبر بروتوكولات مشروعة مثل SMB أو FTP أو حتى HTTP دون أن تلتقطها أدوات المراقبة التقليدية، مما يجعل المؤسسات عرضة لفقدان أصولها الفكرية والمالية دون أن تدري. يأتي هذا المشروع ليسد هذه الفجوة من خلال تصميم وتنفيذ نظام متخصص لمنع فقدان البيانات في شبكات LAN، يعتمد على تقنيات تحليل الحزم العميق (Deep Packet Inspection - DPI) وتتبع الجلسات في الزمن الفعلي. يمزج النظام المقترح بين قدرات التقاط حركة المرور الداخلية وتحليل المحتوى الديناميكي، مع إطار مرن لإدارة سياسات الأمن، مما يمكن المؤسسات من فرض رقابة صارمة على تدفق بياناتها الحساسة داخل محيطها الداخلي. من خلال توفير رؤية شاملة وشفافة لسلوك البيانات، يساهم هذا المشروع في تعزيز الوعي الظرفي (Situational Awareness) لمسؤولي الشبكة، ويمثل إضافة نوعية لأدوات الأمن السيبراني المخصصة للبيئات الداخلية.

1.2 المشكلة الرئيسية

على الرغم من التطور الكبير الذي شهدته حلول أمن المعلومات في السنوات الأخيرة، إلا أن معظم الجهود البحثية والتجارية ركزت على حماية حدود الشبكة من الاختراقات الخارجية، تاركةً فجوة أمنية واضحة تتعلق بمراقبة حركة البيانات داخل الشبكة المحلية (LAN). تكمن المشكلة الجوهرية في أن البيانات الحساسة يمكن أن تُنقل بين الأجهزة الداخلية عبر بروتوكولات وخدمات مشروعة ظاهريًا، مما يجعل اكتشاف محاولات التسرب أمرًا بالغ الصعوبة باستخدام الأدوات التقليدية.

تتفاقم هذه المشكلة في ظل عدة عوامل:

- تنوع قنوات النقل الداخلية: تعتمد المؤسسات على بروتوكولات متعددة لنقل الملفات ومشاركة البيانات داخل الشبكة مثل SMB و FTP و HTTP و HTTPS، مما يخلق سطحًا هجوميًا واسعًا يصعب تغطيته بأدوات المراقبة التقليدية.

- عدم كفاية أدوات التحليل الحالية: بالرغم من قوة أدوات مثل Wireshark وTcpdump ، إلا أنها تتطلب تدخلاً يدوياً وخبرة فنية عالية لتحليل حركة المرور واكتشاف حالات التسرب، كما أنها تفتقر إلى آليات آلية لفرض السياسات الأمنية أو الاستجابة الفورية للانتهاكات.
- غياب آلية فحص المحتوى: تعتمد معظم حلول المراقبة على تحليل رؤوس الحزم (Headers) فقط، دون الخوض في محتوى الحمولة (Payload) ، مما يجعلها غير قادرة على اكتشاف البيانات الحساسة المخبأة داخل محتويات الملفات المنقولة أو نصوص الاتصالات.
- غياب آليات الاستجابة الفورية: تفتقر الحلول الحالية في الغالب إلى القدرة على اتخاذ إجراءات استباقية عند اكتشاف محاولة تسرب، مثل قطع الجلسة المخالفة (Session Termination) أو إصدار إنذار فوري يمكن من خلاله احتواء الحادثة قبل اكتمال نقل البيانات.
- بناءً على ذلك، تتبلور مشكلة البحث في الحاجة الملحة إلى نظام DLP متخصص للشبكات المحلية، قادر على تحليل المحتوى بعمق، وتتبع الجلسات بفعالية، وفرض سياسات أمنية مرنة، مع توفير آليات إنذار واستجابة فورية تمكن المؤسسات من السيطرة الكاملة على بياناتها الحساسة داخلياً.

1.3 هدف المشروع

- يسعى هذا البحث إلى تحقيق هدف رئيسي يتمثل في تصميم وتنفيذ نظام متقدم لمنع فقدان البيانات (DLP) مخصص لبيئات الشبكات المحلية (LAN) ، يتسم بالكفاءة والمرونة والقدرة على التكامل مع البنى التحتية القائمة. يتفرع من هذا الهدف الرئيسي مجموعة من الأهداف التفصيلية:
- التقاط وتحليل حركة المرور الداخلية: تطوير وحدة قادرة على التقاط حزم البيانات من واجهات الشبكة المحلية في الزمن الفعلي (Real-time) ، مع دعم آليات التصفية المتقدمة بناءً على عناوين المصدر والوجهة، المنافذ، والبروتوكولات.
 - فحص المحتوى العميق: (Deep Packet Inspection) تنفيذ آلية متخصصة لفحص حمولة الحزم (Payload) بحثاً عن أنماط بيانات حساسة محددة مسبقاً باستخدام تعبيرات منتظمة (Regular Expressions) وقوائم كلمات مفتاحية، بما يشمل التعرف على أرقام بطاقات الائتمان، المستندات المسربة، والكلمات الاصطلاحية الحساسة.
 - إعادة بناء وتتبع الجلسات: (Session Tracking & Reassembly) بناء محرك قادر على تجميع الحزم المتناثرة في جلسات اتصال كاملة (TCP/UDP) ، وإعادة بناء محتوى الجلسات عالية المستوى) مثل نقل الملفات عبر HTTP/FTP لتقديم سياق متكامل حول عملية نقل البيانات.
 - تطوير إطار مرن لإدارة السياسات: (Policy Management Framework) إنشاء واجهة تسمح لمسؤول النظام بتعريف سياسات أمنية ديناميكية تحدد مصادر البيانات الحساسة، والوجهات المسموحة أو الممنوعة، والبروتوكولات الخاضعة للمراقبة، والإجراء الواجب اتخاذه عند انتهاك السياسة (إنذار، تسجيل، حظر).

- تفعيل آليات الإنذار والاستجابة الفورية: (Real-time Alerting & Response) تصميم نظام إنذار فوري يقوم بإشعار المسؤولين عند اكتشاف أي انتهاك لسياسات DLP ، مع إمكانية تنفيذ إجراءات استباقية تلقائية مثل قطع الجلسة المخالفة عبر إرسال حزم إنهاء الاتصال. (RST Packets)
- تصور البيانات وتوليد التقارير: (Data Visualization & Reporting) إنشاء واجهة مستخدم رسومية (GUI) تعرض لوحة تحكم مركزية تحتوي على إحصائيات حية عن حركة المرور، سجل الإنذارات، الجلسات النشطة، والتقارير التحليلية الشاملة التي تدعم عمليات التدقيق الأمني.

1.4 النظام المقترح

النظام المقترح في هذا البحث هو أداة متخصصة لمنع فقدان البيانات في الشبكات المحلية (LAN DLP System) ، تم تطويرها باستخدام لغة البرمجة بايثون (Python) نظرًا لغناها بالمكتبات المتخصصة في التعامل مع الشبكات وتحليل البيانات. يعتمد النظام على بنية معيارية (Modular Architecture) تتكون من ست وحدات رئيسية متكاملة:

- وحدة التقاط الحزم: (Packet Capture Module) مبنية على مكتبة Scapy، تعمل في وضع المراقبة المباشرة (Promiscuous Mode) لالتقاط كل حركة المرور على الشبكة المحلية. تدعم هذه الوحدة التصفية المسبقة باستخدام Berkeley Packet Filter (BPF) لتقليل الحمل على النظام.
- محرك فحص المحتوى: (Content Inspection Engine) يقوم بفك تغليف البروتوكولات (Protocol Decapsulation) وفحص حمولة الحزم باستخدام خوارزميات بحث فعالة. يتضمن المحرك قاعدة بيانات مدمجة لأنماط البيانات الحساسة (Patterns) قابلة للتوسيع والتحديث الديناميكي.
- محرك تتبع وإعادة بناء الجلسات: (Session Tracking & Reassembly Engine) يعمل هذا المحرك على مستوى أعلى من حزم البيانات المنفردة، حيث يقوم بربط الحزم ذات الصلة بجلسة اتصال واحدة، ويعيد بناء المحتوى الكامل للجلسة (مثل ملف منقول أو صفحة ويب) ليتمكن محرك فحص المحتوى من تحليله ككل.
- محرك إدارة السياسات: (Policy Management Engine) قاعدة بيانات مركزية للقواعد الأمنية، حيث يتم تخزين السياسات بتنسيق منظم. (JSON/SQLite) تدعم السياسات شروطًا متعددة تشمل (المصدر، الوجهة، البروتوكول، نوع البيانات الحساسة، والإجراء المطلوب).
- وحدة الإنذار والاستجابة: (Alerting & Response Module) مسؤولة عن توليد إشعارات فورية عند اكتشاف انتهاك. تشمل آليات الاستجابة:
 - التسجيل: حفظ تفاصيل الحادثة في قاعدة بيانات الإنذارات.
 - الإشعار: عرض إشعار منبثق في واجهة المستخدم الرسومية.
 - الاستجابة النشطة: إرسال حزم RST لقطع جلسات TCP المخالفة، أو تنفيذ أوامر مخصصة (مثل تحديث قواعد جدار الحماية).
- واجهة المستخدم الرسومية: (Graphical User Interface) لوحة تحكم شاملة مطورة باستخدام مكتبة Tkinter و TTKBootstrap، توفر للمسؤول رؤية مركزية لحالة النظام. تتضمن الواجهة:
 - لوحة معلومات رئيسية (Dashboard) تعرض إحصائيات حية.

- نافذة لإدارة السياسات.(Policy Editor)
- سجل إنذارات (Alert Log) قابل للبحث والتصفية.
- عارض للجلسات النشطة والتقارير التاريخية.

1.5 تنظيم التقرير

تم تنظيم هذا التقرير وفقاً للهيكل الأكاديمي المعتمد في الدراسات البحثية، حيث يتكون من سبعة فصول رئيسية:

- الفصل الأول: مقدمة: يقدم هذا الفصل الإطار العام للبحث، بدءاً من عرض السياق الأكاديمي والتطبيقي لمشكلة منع فقدان البيانات في الشبكات المحلية، مروراً بتحديد مشكلة البحث وأهدافه، وصولاً إلى تقديم نظرة عامة على النظام المقترح وهيكل التقرير.
- الفصل الثاني: المفاهيم الأساسية والدراسات المرجعية: يستعرض هذا الفصل الأسس النظرية التي يقوم عليها البحث، بما يشمل تحليل أنظمة DLP، وتقنيات فحص الحزم العميق (DPI)، وبروتوكولات الشبكة ذات الصلة. كما يقدم تحليلاً نقدياً لأحدث ما توصلت إليه الأبحاث (State of the Art) في هذا المجال، ويقارن بين الحلول التجارية والأكاديمية القائمة، ويحدد الفجوة البحثية التي يسدها هذا المشروع.
- الفصل الثالث: الدراسة التحليلية: يتضمن تحليلاً معمقاً لمتطلبات النظام من منظور وظيفي وغير وظيفي، بالإضافة إلى دراسة نماذج التهديدات (Threat Modeling) الخاصة بتسرب البيانات في الشبكات الداخلية، وتحليل حالات الاستخدام (Use Cases) الرئيسية.
- الفصل الرابع: الدراسة التصميمية: يغطي هذا الفصل البنية المعمارية للنظام المقترح، ومخططات تدفق البيانات بين الوحدات المختلفة، وتفاصيل تصميم قاعدة البيانات، وهيكل واجهة المستخدم الرسومية، ومنطق عمل محرك السياسات وآلية فحص المحتوى.
- الفصل الخامس: التنفيذ والاختبار: يصف هذا الفصل الجوانب العملية لتطوير النظام، بما في ذلك بيئة التطوير المستخدمة، والخوارزميات المطبقة في كل وحدة، وتفاصيل البرمجة لمكونات النظام الأساسية مثل التقاط الحزم، تتبع الجلسات، فحص المحتوى، وآلية الحظر النشط.

1.6 خاتمة المقدمة

قدم هذا الفصل الإطار العام لمشروع تصميم وتطوير نظام متخصص لمنع فقدان البيانات (DLP) في الشبكات المحلية (LAN). تم استعراض أهمية هذا النوع من الأنظمة في ظل تزايد الاعتماد على البيانات كأصل استراتيجي، وتفاقم مخاطر التسرب الداخلي الذي لا تغطيه الحلول الأمنية التقليدية بشكل كافٍ. تم تحديد مشكلة البحث بدقة، والتي تتمثل في غياب حلول DLP فعالة تركز على الشبكة الداخلية وتجمع بين فحص المحتوى العميق، وتتبع الجلسات، وآليات الاستجابة الفورية. كما تم صياغة أهداف البحث التي تسعى لسد هذه الفجوة من خلال نظام متكامل يعتمد على بنية معيارية مرنة. تم تقديم وصف موجز للنظام المقترح والمكونات الأساسية له، والتي تشمل وحدات التقاط الحزم، فحص المحتوى، تتبع الجلسات، إدارة السياسات، والإنذار والاستجابة. أخيراً، تم عرض هيكل التقرير الذي يوضح كيفية تنظيم المحتوى العلمي في فصوله السبعة. يشكل هذا الفصل الأساس الذي تُبنى عليه التفاصيل العلمية والتقنية في الفصول اللاحقة.

الفصل الثاني

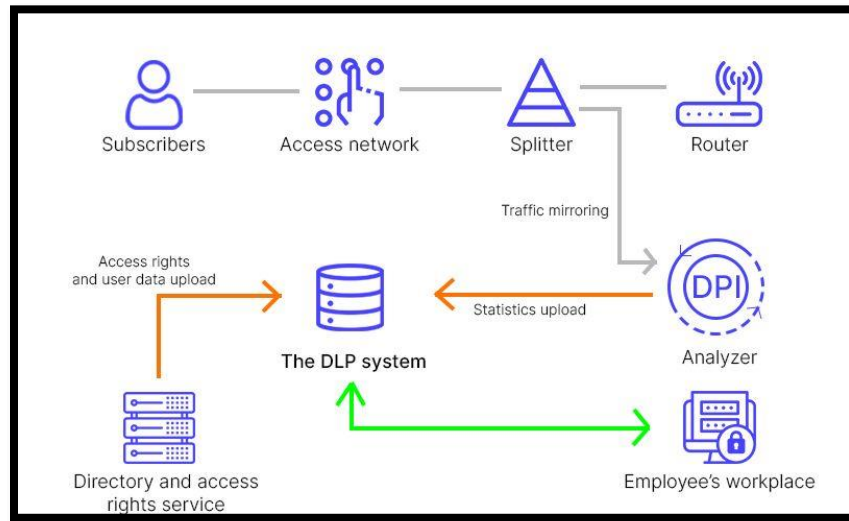
المفاهيم الأساسية والدراسة المرجعية

2.1 المقدمة

في عصر التحول الرقمي السريع، أصبحت البيانات تمثل العصب الرئيسي لأي مؤسسة، سواء كانت حكومية أو خاصة. مع تزايد الاعتماد على الأنظمة السحابية، العمل عن بُعد، وتنوع أجهزة الاتصال، برزت تحديات كبيرة في حماية البيانات الحساسة من التسرب أو الوصول غير المصرح به. تأتي أنظمة منع تسرب البيانات (DLP) كحل استراتيجي متكامل لا يقتصر على وضع جدران دفاعية، بل يمتد ليشمل فهم كيفية تدفق البيانات داخل المؤسسة وخارجها، وتصنيفها، ومراقبتها، واتخاذ إجراءات فورية لحمايتها. يهدف هذا الفصل إلى وضع الأسس النظرية والمعرفية التي تبني عليها متطلبات النظام المقترح، من خلال استعراض مفاهيم DLP الأساسية، آليات عمله، وأنواعه، وصولاً إلى تحليل أحدث ما توصلت إليه الأبحاث في هذا المجال.

2.2 ما هو مفهوم DLP

DLP هو اختصار لـ Data Leakage Prevention (منع تسرب البيانات)، وهو مجموعة من الأدوات والاستراتيجيات المصممة لضمان عدم قيام المستخدمين المصرح لهم بإرسال المعلومات الحساسة أو مشاركتها خارج نطاق الشبكة المسموح به، سواء كان ذلك عن طريق الخطأ أو عن عمد. لا يقتصر مفهوم DLP على منع الخروقات الأمنية فقط، بل يشمل أيضاً اكتشاف ومنع محاولات نقل البيانات التي تنتهك سياسات المؤسسة. يعمل DLP كـ "كاميرا مراقبة" ذكية لحركة البيانات، حيث يقوم بتحليل المحتوى، والسياق، والسلوك المرتبط بالبيانات لاتخاذ القرار المناسب (السماح، الحظر أو التنبيه).



رسم توضيحي 1 : نظام منع تسرب بيانات عام

2.3 كيف يعمل DLP

تعمل أنظمة منع تسرب البيانات (DLP) كمنظومة متكاملة تمر بعدة مراحل متسلسلة تبدأ من لحظة إنشاء البيانات وصولاً إلى لحظة محاولة نقلها أو مشاركتها. لفهم آلية العمل بشكل كامل، يجب تقسيم العملية إلى مراحل منهجية، حيث تعتمد كل مرحلة على مخرجات المرحلة التي تسبقها، وتتكامل مع بقية مكونات النظام.

2.3.1 المراحل الأساسية لعمل نظام DLP

يمكن تلخيص عمل نظام DLP في ست مراحل رئيسية تشكل دورة حياة معالجة البيانات من منظور أمني:

المرحلة	الوصف	المخرجات
الاكتشاف (Discovery)	تحديد مواقع البيانات الحساسة في بيئة المؤسسة (خوادم، أجهزة، سحابة)	خريطة بيانات (Data Map) توضح أماكن تواجد البيانات الحساسة
التصنيف (Classification)	تحليل البيانات وتصنيفها حسب مستوى حساسيتها (عام، داخلي، سري، سري للغاية)	بيانات موسومة (Labeled Data) بفئات الحساسة
وضع السياسات (Policy Definition)	تعريف القواعد التي تحدد كيفية التعامل مع كل فئة من فئات البيانات	مجموعة سياسات (Policy Set) منظمة ومنشورة
المراقبة (Monitoring)	مراقبة حركة البيانات في نقاط مختلفة (شبكة، نقاط نهاية، سحابة)	سجلات أحداث (Event Logs) لحركة البيانات
التحليل (Analysis)	تحليل حركة البيانات مقابل السياسات الموضوعة	قرارات (False Positives, Violations, Matches)
الاستجابة (Response)	تطبيق الإجراءات المناسب بناءً على نتيجة التحليل	حظر، إنذار، تشذير، أو السماح مع التسجيل

جدول 1: المراحل الأساسية لعمل نظام DLP

2.3.2 المرحلة الأولى - الاكتشاف (Discovery)

قبل أن يتمكن نظام DLP من حماية البيانات، يجب أن يعرف أين توجد هذه البيانات. مرحلة الاكتشاف هي عملية مسح شامل (Scanning) لجميع مستودعات البيانات في المؤسسة.

أنواع الاكتشاف:

1. اكتشاف البيانات المخزنة (Data-at-Rest Discovery):

- خوادم الملفات (File Servers): فحص محتويات المشاركات الشبكية (Network Shares) مثل Windows و File Servers و NAS
- أنظمة إدارة المحتوى (CMS): مسح مستودعات مثل SharePoint، Confluence، و Teams
- قواعد البيانات (Databases): فحص جداول SQL و Oracle و MySQL للبحث عن أعمدة تحتوي على بيانات حساسة (مثل أرقام الهوية، بطاقات الائتمان)
- أجهزة المستخدمين: مسح الملفات المخزنة محليًا على أجهزة اللابتوب والموظفين.

2. اكتشاف البيانات أثناء الحركة (Data-in-Motion Discovery):

- يتم بالتوازي مع المراقبة المستمرة لحركة المرور، حيث يتم اكتشاف البيانات الحساسة لحظة محاولة انتقالها عبر الشبكة.

3. اكتشاف البيانات في السحابة (Data-in-Cloud Discovery):

- فحص تطبيقات SaaS المتصلة بالمؤسسة (Shadow IT Discovery) لتحديد التطبيقات غير المصرح بها التي قد تحتوي على بيانات حساسة.

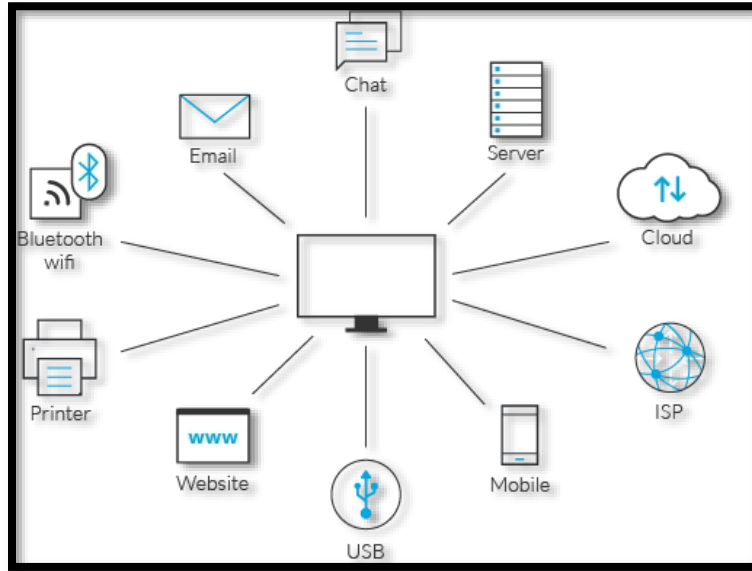
آليات الاكتشاف:

الآلية	الوصف	مثال
المسح المجدول (Scheduled Scanning)	فحص دوري (يومي، أسبوعي) لجميع المستودعات	فحص جميع ملفات SharePoint كل ليلة أحد
المسح المستمر (Continuous Monitoring)	مراقبة لحظية للملفات الجديدة أو المعدلة	فحص أي ملف يتم رفعه إلى Teams فوراً
المسح المبدئي (Initial Baseline Scan)	فحص شامل لمرة واحدة لإنشاء خط أساسي للمخزون	المسح الأولي عند تثبيت النظام

جدول 2: تصنيف آليات الاكتشاف

2.3.3 المرحلة الثانية - التصنيف (Classification)

بعد اكتشاف مواقع البيانات، يتم تحليل المحتوى الفعلي للبيانات لتحديد مستوى حساسيتها. هذه المرحلة هي الأكثر أهمية لأن دقتها تحدد فعالية النظام بالكامل.



رسم توضيحي 2: أنواع التصنيف في DLP

طرق التصنيف:

1. التصنيف الآلي (Automated Classification):

- باستخدام التعبيرات المنتظمة (Regex): البحث عن أنماط محددة. مثال {14}d \: للبحث عن أرقام هوية وطنية.
 - باستخدام البصمات الرقمية (Fingerprinting): أخذ عينة فريدة من مستند مرجعي (مثل عقد سري) ومقارنة الملفات الأخرى بها.
 - باستخدام التعلم الآلي (ML): تدريب نموذج على فهم سياق البيانات. مثال: التمييز بين "سرطان الثدي" كمصطلح طبي عادي و"تقرير حالة مريضة سرطان الثدي" كبيانات طبية حساسة.
 - باستخدام الكلمات المفتاحية (Keywords): البحث عن كلمات محددة مثل "سري"، "سري للغاية"،
2. التصنيف اليدوي (Manual Classification):
- يقوم المستخدم بتحديد مستوى حساسية الملف عند إنشائه أو تعديله.
 - يظهر مربع حوار للمستخدم يسأله: "ما مستوى حساسية هذا المستند؟"
 - يتم تذكير المستخدم بالسياسات قبل حفظ الملف.
3. التصنيف الهجين (Hybrid Classification):
- يجمع بين التصنيف الآلي واليدوي. يقوم النظام باقتراح تصنيف، ويحق للمستخدم تعديله مع تسجيل ذلك في السجلات.
- مستويات التصنيف النموذجية:

المستوى	الوصف	أمثلة	السياسات المطبقة
عام (Public)	معلومات يمكن نشرها للعموم	المنشورات التسويقية، البيانات الصحفية	لا توجد قيود
داخلي (Internal)	معلومات للاستخدام الداخلي فقط	النشرات الداخلية، جداول المناوبات	منع النشر خارج النطاق الداخلي
سري (Confidential)	معلومات حساسة للمؤسسة	البيانات المالية، عقود الموردين	حظر النقل عبر البريد الشخصي، تشفير الإرسال الخارجي
سري للغاية (Restricted)	معلومات شديدة الحساسية	الملكية الفكرية، بيانات العملاء، ملفات HR	حظر كامل للنقل خارج النطاق المسموح، تنبيه فوري للأمن

جدول 3: مستويات التصنيف النموذجية

2.3.4 المرحلة الثالثة - وضع السياسات (Policy Definition)

السياسة في DLP هي مجموعة من القواعد التي تحدد "من" يمكنه فعل "ماذا" بـ "أي بيانات" إلى "أين" باستخدام "أي أداة".

مكونات السياسة الأساسية:

1. الشروط (Conditions): وهي ما يعرف بـ "نطاق السياسة: (Policy Scope)"
 - المستخدم (Who): مستخدم محدد، مجموعة، دور وظيفي، أو جميع المستخدمين.

- البيانات (What): فئة البيانات (بطاقات ائتمان، هويات وطنية، مستندات هندسية)، مستوى التصنيف (سري، داخلي)، أو مستودع محدد.
 - الوجهة (Where): نطاق داخلي، نطاق خارجي، تطبيق محدد (Gmail، Dropbox)، عنوان IP، أو نطاق جغرافي.
 - القناة (How): البريد الإلكتروني، HTTP/HTTPS، FTP، USB، الطابعات، تطبيقات المراسلة.
2. الإجراءات (Actions)
- المراقبة فقط (Monitor Only): تسجيل الحدث دون أي تدخل.
 - الإنذار (Alert): إرسال إشعار إلى مسؤول الأمن.
 - الحظر (Block): منع العملية بالكامل مع عرض رسالة للمستخدم.
 - العزل (Quarantine): عزل البريد الإلكتروني أو الملف للمراجعة اليدوية.
 - التشفير (Encrypt): تشفير البريد الإلكتروني أو الملف تلقائيًا قبل الإرسال.
 - التثقيف (Notify & Educate): عرض رسالة توعوية للمستخدم مع السماح بالعملية بعد التأكيد.
3. الاستثناءات (Exceptions)
- تعريف حالات يُسمح فيها بانتهاك السياسة بشكل صريح.
 - مثال: السماح بإرسال ملفات سرية إلى partner@trustedcompany.com رغم منع الإرسال الخارجي بشكل عام.

2.3.5 المرحلة الرابعة - المراقبة (Monitoring)

مرحلة المراقبة هي العيون والأذان للنظام، حيث يتم تتبع حركة البيانات عبر نقاط مختلفة في البنية التحتية.

أنواع نقاط المراقبة:

1. مراقبة الشبكة (Network Monitoring)
 - يتم تثبيت جهاز DLP أو جهاز افتراضي عند بوابة الشبكة (Gateway).
 - يتم اعتراض حركة المرور عبر:
 - وضع الجسر الشفاف (Transparent Bridge): يوضع الجهاز بين الراوتر والSwitch، ولا يحتاج تغيير إعدادات الشبكة.
 - وضع الوكيل (Proxy): يتم توجيه حركة المرور إلى وكيل DLP.
 - وضع (Port Mirroring): SPAN يتم نسخ حركة المرور إلى منفذ مخصص للتحليل دون التأثير على تدفق البيانات.
2. مراقبة نقاط النهاية (Endpoint Monitoring)
 - يتم تثبيت وكيل برمجي (Agent) على جهاز المستخدم.
 - يقوم الوكيل بمراقبة:
 - نظام الملفات: إنشاء، تعديل، نسخ، نقل الملفات.

- التطبيقات: ما هي التطبيقات التي تصل إلى الملفات الحساسة.
- الأجهزة الطرفية: توصيل USB ، الطباعة ، نقل الملفات عبر Bluetooth.
- الحافظة: (Clipboard) عمليات النسخ واللصق.

3. مراقبة السحابة (Cloud Monitoring)

- يتم التكامل عبر APIs مع تطبيقات SaaS مثل Microsoft 365 ، Slack ، Google Workspace ، Salesforce.
- يتم مراقبة:
 - مشاركة الملفات خارج المؤسسة.
 - تنزيل كميات كبيرة من البيانات.
 - تسجيل الدخول من مواقع غير معتادة.

2.3.6 المرحلة الخامسة - التحليل (Analysis)

هذه المرحلة هي "عقل" النظام، حيث يتم اتخاذ القرارات بناءً على البيانات المجمعة من نقاط المراقبة مقابل السياسات الموضوعية.

تقنيات التحليل:

1. تحليل المحتوى (Content Analysis)

- مطابقة دقيقة (Exact Match): مقارنة الملف مع قاعدة بيانات من المستندات المرجعية.
- مطابقة جزئية (Partial Match): البحث عن أجزاء من البيانات الحساسة داخل ملف أكبر.
- تحليل متجه (Vector Analysis): مقارنة تشابه المستندات باستخدام تقنيات الذكاء الاصطناعي.

2. تحليل السياق (Contextual Analysis)

- من هو المستخدم؟ (المستخدم نفسه، مستخدم مخترق، مستخدم في إجازة)
- إلى أين ترسل البيانات؟ (وجهة داخلية موثوقة، منافس تجاري، دولة ذات مخاطر عالية)
- بأي أداة؟ (تطبيق معتمد، أداة دردشة غير مصرح بها)
- متى؟ (ساعات العمل الرسمية، منتصف الليل، قبل تقديم الاستقالة مباشرة)

3. تحليل السلوك (Behavioral Analysis - UEBA)

- بناء خط أساسي (Baseline) للسلوك الطبيعي لكل مستخدم.
- اكتشاف الشذوذ (Anomalies)
 - حجم غير معتاد: مستخدم يرسل عادة 10 ميجابايت، يرسل فجأة 2 جيجابايت.
 - تكرار غير معتاد: مستخدم يقوم بعمليات تنزيل متكررة من قاعدة البيانات في وقت قصير.
 - وجهة غير معتادة: مستخدم يرسل بيانات إلى دولة لا يتعامل معها عادة.

4. معالجة الإيجابيات الخاطئة (False Positive Management)

- من أكبر التحديات في أنظمة DLP

- يتم استخدام تقنيات مثل:
 - القوائم البيضاء (Whitelists): استثناء تطبيقات أو جهات معينة.
 - التعلم المستمر (Continuous Learning): تحديث نماذج التحليل بناءً على مراجعات المسؤولين.
 - وضع المراقبة (Monitor Mode): قبل تفعيل وضع الحظر، يتم تشغيل النظام في وضع المراقبة لفترة كافية لضبط السياسات وتقليل الإيجابيات الخاطئة.

2.3.7 المرحلة السادسة - الاستجابة (Response)

عند اتخاذ قرار بأن هناك انتهاكاً للسياسة (أو شبه انتهاك)، يتم تفعيل آلية الاستجابة المناسبة وفق أنماط الاستجابة التالية

متى يستخدم	الوصف	نمط الاستجابة
للسياسات عالية الخطورة (مثل نقل بيانات سرية للغاية)	منع العملية فوراً دون تدخل بشري	الحظر التلقائي (Auto-Block)
للسياسات متوسطة الخطورة أو وضع المراقبة الأولي	تسجيل الحدث وإرسال تنبيه للمسؤول	الإنذار فقط (Alert Only)
عندما يكون القرار غير واضح ويتطلب مراجعة بشرية	عزل البريد/الملف وصندوق انتظار للمسؤول	العزل للمراجعة (Quarantine)
للسياسات منخفضة الخطورة أو للمستخدمين المصرح لهم	السماح بالعملية ولكن تسجيلها للتدقيق لاحقاً	السماح مع التسجيل (Allow with Log)
لزيادة الوعي الأمني وتقليل الحظر المزعج	عرض رسالة للمستخدم توضح سبب المنع وكيفية التصحيح، ثم السماح بعد التأكيد	التثقيف التفاعلي (Interactive Education)

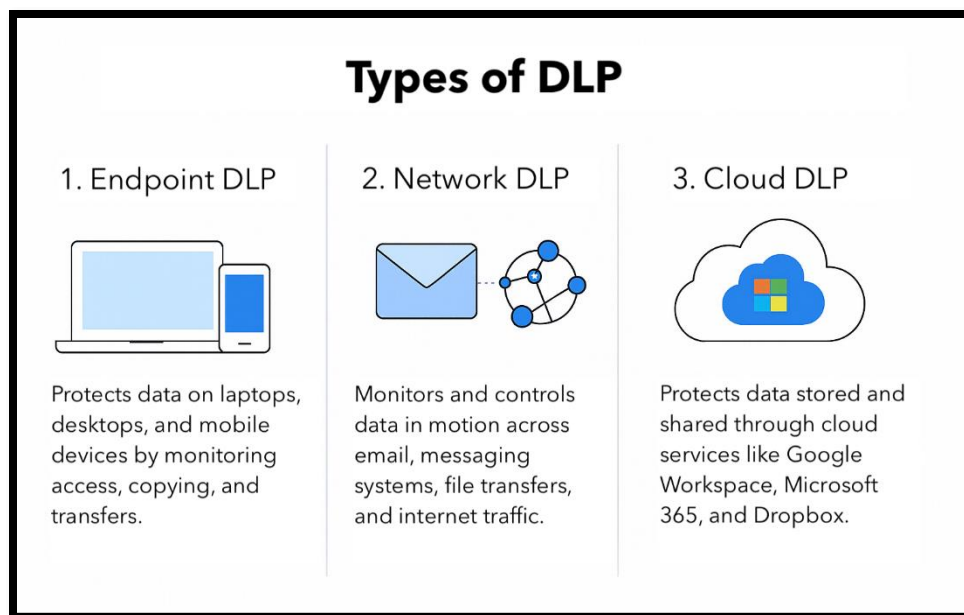
جدول 4: آليات الاستجابة

2.4 أنواع (DLP (Data Leakage Prevention Types

تصنف أنظمة منع تسرب البيانات (DLP) بناءً على عدة معايير، أهمها موقع النشر (Deployment Location)، طريقة الحماية (Protection Approach)، ونوع البيانات المستهدفة (Data State). يتطلب بناء نظام DLP متكامل فهماً عميقاً لهذه التصنيفات لاختيار المزيج المناسب الذي يلبي احتياجات المؤسسة.

2.4.1 التصنيف حسب موقع النشر (Deployment-Based Classification)

هذا هو التصنيف الأكثر شيوعاً في الصناعة، حيث يقسم حلول DLP إلى ثلاثة أنواع رئيسية بناءً على المكان الذي يتم فيه تثبيت وحدات المراقبة والتنفيذ.



رسم توضيحي 3 : انواع DLP حسب موقع النشر

2.4.1.1 Network DLP على مستوى الشبكة

التعريف:

يتم تثبيته كجهاز مادي (Appliance) أو جهاز افتراضي (Virtual Appliance) عند نقاط الخروج من الشبكة (Egress Points) لمراقبة وتحليل حركة المرور الصادرة والواردة. يعمل كـ "بوابة أمنية" تفحص كل حزمة بيانات تغادر المؤسسة أو تدخل إليها.

آلية العمل:

- يتم وضع جهاز Network DLP في مسار حركة المرور (Inline) بين الراوتر الرئيسي والشبكة الداخلية.
- يقوم بفحص البروتوكولات المختلفة (SMTP: البريد الإلكتروني، HTTP/HTTPS الويب، FTP (نقل الملفات)، وحتى بروتوكولات المشاركة مثل SMB.
- يستخدم تقنيات مثل Deep Packet Inspection (DPI) و SSL/TLS Interception لفحص المحتوى المشفر.

المزايا:

الميزة	الوصف
تغطية شاملة	يغطي جميع الأجهزة المتصلة بالشبكة دون الحاجة لتثبيت برامج على كل جهاز
مركزية التحكم	إدارة موحدة من نقطة واحدة، سهولة تحديث السياسات
لا يعتمد على نظام التشغيل	يعمل مع Windows ، macOS ، Linux ، الأجهزة المحمولة، والأجهزة غير المدارة
مراقبة تطبيقات السحابة	يكتشف استخدام تطبيقات Shadow IT ويمنع نقل البيانات إليها

جدول 5 : مزايا DLP على مستوى الشبكة

التحديات:

الوصف	التحدي
مع انتشار TLS 1.3 والتشفير الشامل (E2EE)، يصعب فحص المحتوى	التشفير المتزايد
قد يسبب تأخيرًا في حركة المرور إذا لم يكن مصممًا بشكل جيد	زمن الانتقال (Latency)
لا يحمي البيانات عندما يكون الجهاز خارج الشبكة (مثل العمل عن بُعد)	لا يغطي الأجهزة غير المتصلة
لا يتحكم في منافذ USB أو الطابعات المحلية	الأجهزة الطرفية

جدول 6: التحديات التي تواجه DLP على مستوى الشبكة

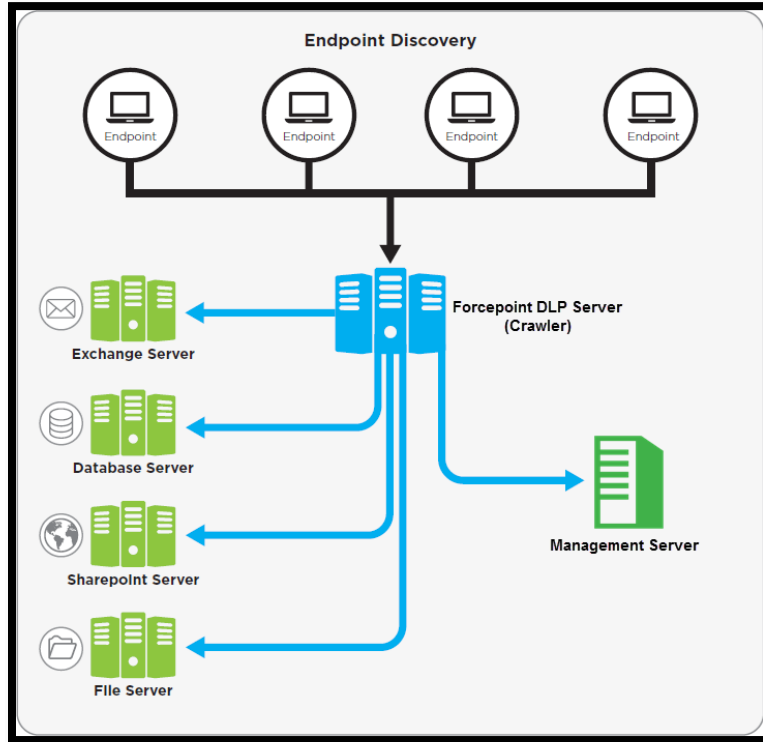
حالات الاستخدام المناسبة:

- المؤسسات التي تعتمد بشكل كبير على البريد الإلكتروني والتطبيقات السحابية.
- البيئات التي تحتوي على أجهزة غير مُدارة (BYOD - Bring Your Own Device).
- مراقبة حركة المرور الصادرة من مراكز البيانات والخوادم.

Endpoint DLP 2.4.1.2 على مستوى نقاط النهاية

التعريف:

يتم تثبيته كبرنامج وكيل (Agent) على أجهزة المستخدمين النهائيين (اللابتوب، الحواسيب المكتبية، الخوادم، الأجهزة المحمولة). يعمل بشكل مستقل عن اتصال الشبكة، مما يجعله الحل الأمثل للعمل عن بُعد والبيئات الموزعة.



رسم توضيحي 4: Endpoint DLP على مستوى نقاط النهاية

آلية العمل:

- الوكيل المثبت على الجهاز يتكامل مع نظام التشغيل على مستوى Kernel أو User Mode.
- يراقب عمليات النظام: نظام الملفات (File System) ، الحافظة (Clipboard) ، التطبيقات الجارية ، والأجهزة المتصلة.
- يطبق السياسات محليًا حتى عندما يكون الجهاز غير متصل بالشبكة المركزية. (Offline Mode)

مكونات المراقبة على Endpoint

المكون	الوصف	أمثلة على المراقبة
الأجهزة الطرفية (Peripheral Control)	التحكم في منافذ الاتصال والأجهزة المتصلة	CD/DVD ، الطابعات ، Wi-Fi Direct ، Bluetooth ، USB
التطبيقات (Application Control)	مراقبة والتحكم في التطبيقات التي تصل للبيانات	منع تطبيقات الدردشة من قراءة ملفات سرية
الحافظة (Clipboard Control)	مراقبة عمليات النسخ واللصق	منع لصق بيانات حساسة في تطبيقات غير مصرح بها
لقطات الشاشة (Screen Capture)	منع أو تسجيل محاولات تصوير الشاشة	حظر تطبيقات Snip & Sketch عند فتح مستند سري
الطباعة (Print Control)	التحكم في عمليات الطباعة	منع طباعة مستندات سرية أو تسجيل من قام بالطباعة
نقل الملفات (File Transfer)	مراقبة نقل الملفات بين التطبيقات	منع نسخ ملف من مجلد محمي إلى مجلد عام

جدول 7 : مكونات المراقبة على Endpoint

المزايا:

الميزة	الوصف
حماية غير متصلة (Offline Protection)	يستمر في العمل حتى عندما يكون الجهاز خارج الشبكة
تحكم كامل بالأجهزة الطرفية	يتحكم في USB ، Bluetooth ، الطابعات ، وغيرها
رؤية شاملة لسلوك المستخدم	يلتقط جميع أنشطة المستخدم على الجهاز، بما فيها التي لا تمر عبر الشبكة
حماية البيانات المخزنة محليًا	يمنع وصول التطبيقات الضارة إلى الملفات المحلية

جدول 8 : مزايا مكونات المراقبة على Endpoint

التحديات:

الوصف	التحدي
تحديث وتكوين الآلاف من الأجهزة يتطلب بنية تحتية قوية	إدارة معقدة على نطاق واسع
قد يؤثر على أداء الجهاز إذا لم يكن مصممًا بكفاءة	استهلاك موارد الجهاز
قد يواجه مشكلات مع تحديثات نظام التشغيل أو التطبيقات	توافق مع أنظمة التشغيل
المستخدمون ذوو الصلاحيات العالية قد يتمكنون من تعطيل الوكيل	إمكانية إلغاء التثبيت

جدول 9 : التحديات التي تواجه مكونات المراقبة على Endpoint

حالات الاستخدام المناسبة:

- المؤسسات التي تعتمد على العمل عن بُعد (Remote Work) أو العمل الميداني.
- البيانات التي تحتوي على بيانات حساسة للغاية (مؤسسات مالية، حكومية، صحية).
- التحكم في الأجهزة الطرفية ومنع تسرب البيانات عبر USB.

Cloud DLP 2.4.1.3 على مستوى الخدمات السحابية

التعريف:

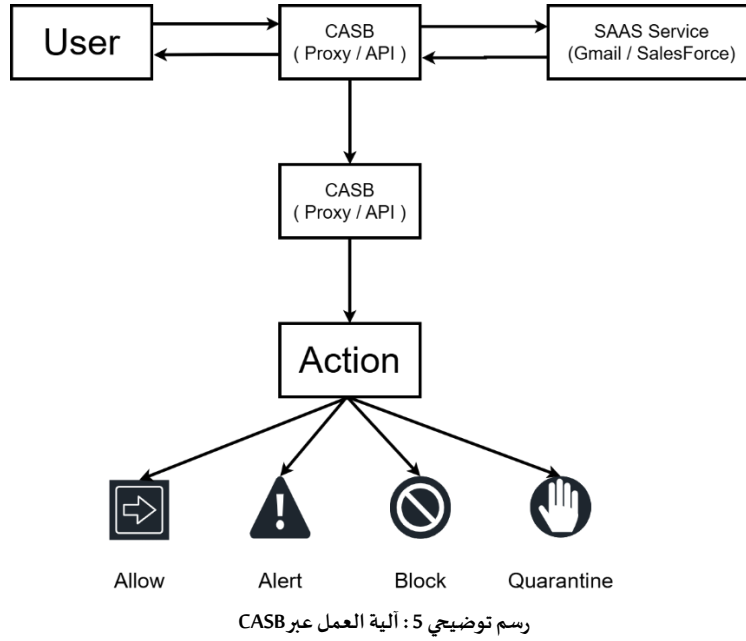
حل مصمم خصيصًا لحماية البيانات في البيئات السحابية، سواء كانت تطبيقات SaaS مثل Microsoft 365 ، Google Workspace ، Salesforce ، Slack أو بنى تحتية سحابية (IaaS/PaaS) مثل AWS ، Azure ، GCP.

أنواع Cloud DLP مع أمثلة

أمثلة	الوصف	النوع
Google Purview DLP ، Microsoft Workspace DLP	حلول مدمجة داخل تطبيقات SaaS نفسها	SAAS DLP مدمج
iBoss ، McAfee MVISION Cloud ، Netskope	طبقة وسيطة بين المستخدمين ومزودي الخدمات السحابية	CASB (Cloud Access Security Broker)
مراقبة ملفات SharePoint و Teams عبر APIs	يتكامل عبر APIs مع تطبيقات SaaS لمراقبة البيانات المخزنة	API-based DLP
Azure Information Protection ، AWS Macie	حلول مدمجة في البنية التحتية السحابية (IaaS)	Cloud Native DLP

جدول 10 : أنواع Cloud DLP

آلية العمل عبر CASB



المزايا:

الميزة	الوصف
تغطية تطبيقات SaaS	يغطي التطبيقات السحابية الأكثر استخداماً (Office 365 ، Gmail ، Slack)
لا يحتاج تثبيت على الأجهزة	يعمل عبر APIs أو وكيل (Proxy) بدون تدخل على جهاز المستخدم
مرونة التوسع (Scalability)	يتكيف مع نمو استخدام المؤسسة للتطبيقات السحابية
اكتشاف Shadow IT	يكتشف التطبيقات السحابية غير المصرح بها التي يستخدمها الموظفون

جدول 11 : مزايا CASB

التحديات:

التحدي	الوصف
الاعتماد على APIs	بعض التطبيقات لا توفر APIs كافية للمراقبة الشاملة
خصوصية البيانات	تمرير البيانات عبر CASB قد يثير مخاوف خصوصية في بعض المؤسسات
تعدد البائعين	التعامل مع عدة مزودين سحابيين قد يعقد التكوين والإدارة
تكلفة إضافية	معظم حلول Cloud DLP تتطلب اشتراكات إضافية بجانب اشتراكات SaaS

جدول 12 : عيوب CASB

حالات الاستخدام المناسبة:

- المؤسسات التي تعتمد بشكل كبير على Microsoft 365 أو Google Workspace.
- بيئات العمل الهجين (Hybrid Work) حيث يعتمد الموظفون على تطبيقات سحابية.
- المؤسسات التي تنتقل إلى السحابة بالكامل (Cloud-First Strategy).

2.4.2 التصنيف حسب طريقة الحماية (Protection Approach-Based Classification)

العيوب	المزايا	الوصف	النوع
قد يسبب زمن انتقال (Latency)؛ يتطلب معالجة عالية الأداء؛ صعوبة في التعامل مع التشفير.	يمنع التسرب بشكل فوري؛ لا حاجة لتدخل بشري؛ يقلل من مخاطر فقدان البيانات.	يتم وضع النظام في مسار حركة البيانات (In-line)، مما يسمح بمنع الانتهاكات قبل حدوثها. يعمل كـ "بوابة" تفحص وتمنع في الوقت الفعلي.	الحماية الفورية (Inline DLP)
لا يمنع الانتهاكات في الوقت الفعلي؛ يعتمد على قدرات APIs المتاحة.	لا يؤثر على أداء المستخدم؛ يغطي البيانات المخزنة (Data-at-Rest)؛ سهل التكامل مع تطبيقات SaaS.	يتكامل مع التطبيقات عبر APIs لمراقبة البيانات المخزنة وتحليلها. يعمل بشكل غير متزامن (Async) ولا يتداخل مع تدفق البيانات الفوري.	الحماية عبر الواجهات (API-Based DLP)
أعلى تكلفة؛ تعقيد في الإدارة والتكوين.	أفضل توازن بين الأداء والحماية؛ تغطية شاملة للبيانات أثناء الحركة والمخزنة.	يجمع بين Inline و API-based لتحقيق حماية شاملة. يستخدم Inline للمراقبة الفورية، و API لفحص البيانات المخزنة والتحليل العميق.	الحماية الهجينة (Hybrid DLP)

جدول 13 : أنواع طرق الحماية

2.4.3 التصنيف حسب حالة البيانات (Data State-Based Classification)

أمثلة	آلية الحماية	الوصف	حالة البيانات
فحص ملفات SharePoint للبحث عن بيانات حساسة غير محمية.	المسح الدوري (Scanning)، التصنيف الآلي، تطبيق الصلاحيات، التشفير.	البيانات المخزنة على خوادم، أجهزة تخزين، قواعد بيانات، أو أجهزة المستخدمين.	البيانات المخزنة Data-at-Rest
فحص مرفقات البريد الإلكتروني قبل إرسالها خارج المؤسسة.	مراقبة الشبكة (Network DLP)، فحص الحزم، تحليل البروتوكولات.	البيانات المنقولة عبر الشبكة) بريد إلكتروني، ويب، FTP، مراسلة فورية).	البيانات أثناء الحركة Data-in-Motion
منع لصق بيانات حساسة من CRM إلى تطبيق دردشة غير مصرح به.	مراقبة نقاط النهاية (Endpoint DLP)، التحكم في الحافظة، مراقبة التطبيقات.	البيانات التي يتم الوصول إليها أو معالجتها بواسطة التطبيقات أو المستخدمين.	البيانات قيد الاستخدام Data-in-Use

جدول 14 : أنواع البيانات التي يتعامل معها DLP

2.4.4 التصنيف حسب المصدر (Vendor-Based Classification)

بالإضافة إلى التصنيفات التقنية، يمكن تصنيف حلول DLP حسب طبيعة المصدر:

التحديات	المزايا	الوصف	النوع
----------	---------	-------	-------

محدودية الميزات مقارنة بالحلول المتخصصة؛ لا يغطي البيانات غير المتجانسة.	تكامل سلس، لا تكلفة إضافية، سهولة الإدارة في البيئات المتجانسة.	حلول مدمجة في أنظمة التشغيل مثل Microsoft Purview (Windows/Office 365) أو Google Workspace DLP.	مدمج في نظام التشغيل Native OS DLP
قد لا يكون متخصصًا مثل الحلول المستقلة؛ اعتماد على النظام البيئي للبائع.	تكامل مع جدار الحماية، SIEM، وXDR؛ إدارة مركزية.	جزء من منصة أمنية أكبر مثل Cisco Palo Alto Prisma، أو Trellix، أو Secure.	مدمج في منصة أمنية شاملة Integrated DLP
تكلفة أعلى؛ يتطلب تكامل مع أنظمة أخرى للحصول على رؤية أمنية كاملة.	مميزات متقدمة؛ مرونة عالية؛ دعم للبيئات المعقدة.	حلول متخصصة تركز فقط على DLP مثل Forcepoint، Digital Guardian، Symantec (Broadcom).	متخصص Standalone
دعم محدود؛ عدم وجود تحديثات أمنية منتظمة؛ يتطلب خبرة تقنية عالية.	تكلفة منخفضة (مجاني)؛ مرونة في التعديل والتخصيص.	مشاريع مفتوحة المصدر مثل OpenDLP، أو Apache Spot، أو MyDLP.	مفتوح المصدر Open Source DLP

جدول 15: تصنيف حلول DLP حسب طبيعة المصدر

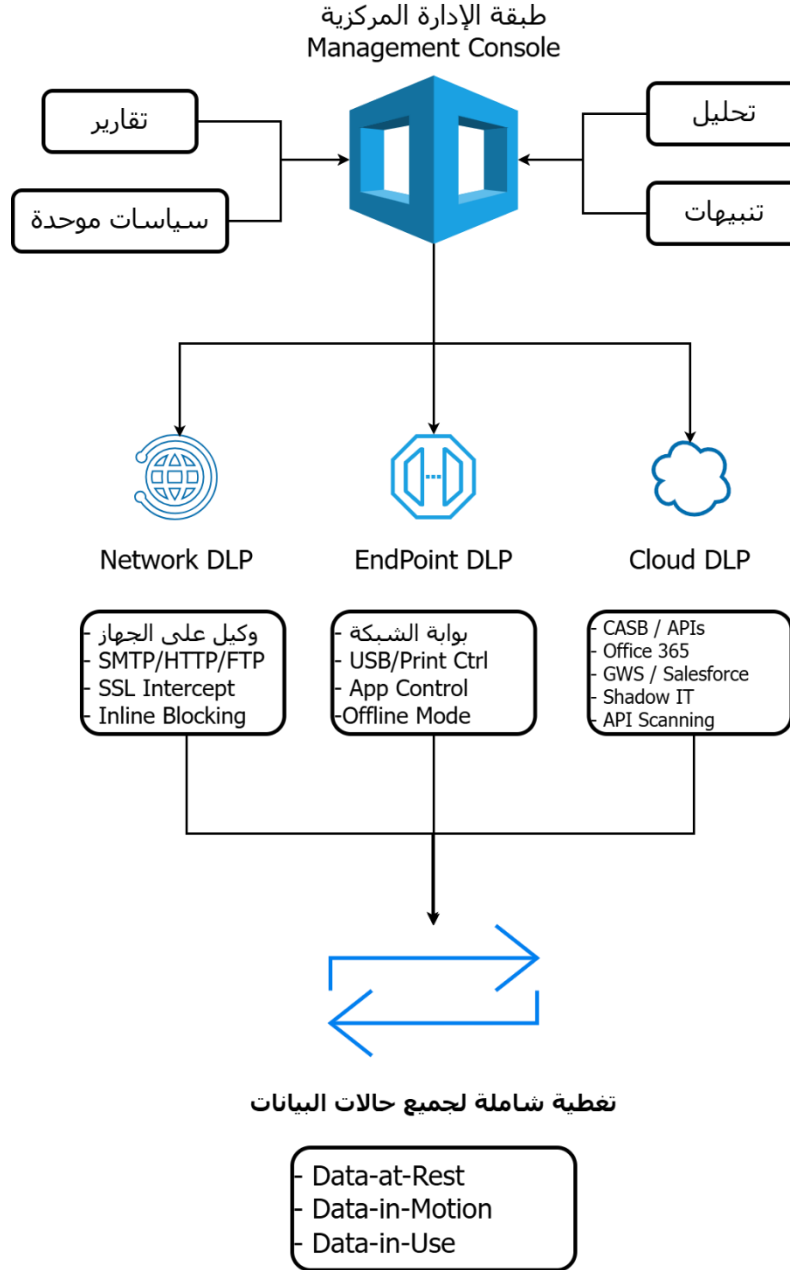
2.4.5 جدول مقارنة شامل لأنواع DLP

معيار المقارنة	Network DLP	Endpoint DLP	Cloud DLP (CASB)
موقع النشر	بوابة الشبكة (Gateway)	على جهاز المستخدم (Agent)	بين المستخدم والسحابة
التغطية	جميع الأجهزة على الشبكة	الأجهزة المثبت عليها الوكيل فقط	تطبيقات SaaS والسحابية
الحماية أثناء عدم الاتصال	لا يعمل	يعمل (Offline Mode)	يعمل عبر APIs
التحكم في USB والطابعات	لا يتحكم	يتحكم بشكل كامل	لا يتحكم
مراقبة التطبيقات	محدودة (فحص حركة الشبكة)	شاملة	عبر APIs حسب قدرات التطبيق
التأثير على الأداء	قد يسبب تأخير في الشبكة	قد يستهلك موارد الجهاز	تأثير API ضئيل
التكامل مع SIEM	مرتفع	مرتفع	مرتفع
البيئة المناسبة	بيئات المكاتب المستقرة	بيئات العمل عن بُعد والميدانية	بيئات السحابة والعمل الهجين
أمثلة على حلول	Forcepoint Network DLP، Cisco Email Security	Trellix Endpoint DLP، Digital Guardian	Microsoft، Netskope، iBoss، Purview

جدول 16: مقارنة عامة بين أنواع DLP

2.4.6 نموذج النشر المتكامل (Integrated Deployment Model)

في المؤسسات الحديثة، نادرًا ما يتم الاعتماد على نوع واحد فقط من DLP النموذج الأمثل هو النشر المتكامل الذي يجمع بين الأنواع الثلاثة لتحقيق حماية شاملة متعددة الطبقات. (Defense in Depth)



رسم توضيحي 6 : الهيكلية العامة لنظام DLP

مزايا النموذج المتكامل:

1. تغطية شاملة: حماية البيانات في جميع حالاتها (مخزنة، منقولة، قيد الاستخدام).
2. تطبيق سياسات موحد: سياسة واحدة يتم تطبيقها عبر جميع النقاط.
3. رؤية مركزية: لوحة تحكم واحدة لجميع الأحداث والتنبيهات.
4. مرونة النشر: القدرة على إضافة أو إزالة طبقات حسب الاحتياجات.

2.4.7 معايير اختيار النوع المناسب من DLP

عند اختيار نوع DLP المناسب لمشروعك، يجب مراعاة العوامل التالية:

المعيار	الأسئلة التي يجب طرحها
بنية المؤسسة	هل تعتمد المؤسسة على العمل عن بُعد؟ هل لدينا أجهزة غير مُدارة (BYOD)؟ هل نستخدم تطبيقات سحابية بكثافة؟
طبيعة البيانات	هل البيانات الحساسة مركزة على الخوادم أم موزعة على أجهزة المستخدمين؟ هل هناك حماية للبيانات المخزنة محلياً؟
الميزانية	هل لدينا ميزانية لتثبيت وكلاء على كل جهاز؟ هل نفضل نموذج اشتراك (SaaS) أم ترخيص دائم (On-prem)؟
الموارد البشرية	هل لدينا فريق لتشغيل وإدارة النظام؟ هل نفضل حلاً مداراً (Managed Service) أم ذاتي الإدارة؟
المتطلبات التنظيمية	هل هناك متطلبات تنظيمية مثل HIPAA ، GDPR ، PCI-DSS تتطلب أنواعاً معينة من الحماية؟

جدول 17 : عوامل اختيار DLP

2.5 ما هو DLP System

نظام DLP ليس مجرد برنامج واحد، بل هو منصة متكاملة تجمع بين البرمجيات (Software) ، والسياسات (Policies) ، وإجراءات العمل (Workflows) يعمل النظام بشكل مركزي حيث يقوم مدير الأمن بتعريف السياسات عبر وحدة تحكم إدارة مركزية (Management Console) ، ثم تقوم وكلاء (Agents) أو أجهزة استشعار (Sensors) موزعة على الشبكة، والخوادم، والمتصفحات، والأجهزة الطرفية بتنفيذ هذه السياسات والإبلاغ عن الحوادث. يشمل النظام أيضاً قاعدة بيانات مركزية لتخزين السجلات والتقارير التحليلية.

2.6 كيف يعمل DLP بالتفصيل حسب بيئة النشر

2.6.1 على الخوادم (Servers)

يعمل DLP على الخوادم من خلال تثبيت وكيل برمجي أو التكامل مع نظام التشغيل لمراقبة:

- المستودعات: فحص الملفات المخزنة على File Servers ، SharePoint ، أو قواعد البيانات للتأكد من عدم وجود بيانات حساسة في غير مكانها. (Data-at-Rest)
- التطبيقات: مراقبة التطبيقات التي تعمل على الخادم والتي تتعامل مع البيانات الحساسة، مثل تطبيقات ERP أو CRM ، لمنع التصدير غير المصرح به.

2.6.2 على المتصفحات (Browsers)

تتم المراقبة على المتصفحات عبر طريقتين رئيسيتين:

1. وكيل الشبكة (Proxy): تحليل حركة HTTPS الصادرة من المتصفح لاكتشاف محاولات رفع الملفات الحساسة إلى مواقع مثل Gmail ، Dropbox ، أو ChatGPT.
2. الإضافات (Browser Extensions): في بيئات العمل المُدارة، يمكن دفع إضافة DLP للمتصفح تمنع نسخ ولصق البيانات الحساسة في حقول النصوص غير المصرح بها، أو تمنع تحميل الملفات بناءً على محتواها.

2.6.3 على طرفيات الموظفين (Endpoints)

هذا هو المستوى الأكثر تعقيدًا وتحكمًا. يقوم وكيل (Agent) مثبت على نظام تشغيل المستخدم Linux ، macOS ، Windows بما يلي:

- التحكم في الأجهزة الطرفية: منع أو تقييد استخدام منافذ USB ، Bluetooth ، أو الطابعات.
- مراقبة التطبيقات: التحكم في أي تطبيق يمكنه الوصول إلى البيانات الحساسة (مثل منع تطبيق دردشة مشفرة غير معتمد من إرسال ملف).
- النقاط الشاشة: تسجيل شاشة المستخدم عند حدوث انتهاك محتمل لتوفير أدلة جنائية. (Forensic Evidence)
- الوضع غير المتصل (Offline Mode): الاستمرار في تطبيق السياسات حتى عندما لا يكون الجهاز متصلاً بالشبكة المركزية.

2.7 التقاط وتحليل حركة المرور الداخلية

لا يقتصر دور DLP على مراقبة الحدود الخارجية فقط، بل يمتد ليشمل حركة المرور الداخلية (East-West Traffic) داخل مركز البيانات أو الشبكة الداخلية. يتم ذلك عبر:

- SPAN Ports أو TAPs: توجيه نسخة من كل حزمة بيانات تمر عبر الشبكة إلى محرك تحليل DLP.
- Deep Packet Inspection (DPI): تجاوز رؤوس الحزم (Headers) لفحص المحتوى الفعلي للبيانات، حتى لو كانت البيانات مضغوطة أو مشفرة جزئيًا في حالة (TLS interception).
- تحليل السلوك: بناء خط أساسي لحركة المرور. إذا حاول خادم قاعدة بيانات فجأة إنشاء اتصال بخادم خارجي في منتصف الليل وإرسال كميات كبيرة من البيانات، يعتبر هذا سلوكًا شاذًا يتم اكتشافه.

2.8 فحص المحتوى العميق (Deep Content Inspection)

هو جوهر نظام DLP ، حيث لا يكفي النظام بفحص امتداد الملف أو اسمه، بل يفتح الملف فعليًا لتحليل محتواه. تشمل التقنيات المستخدمة:

- البصمة البيانية (Indexed Document Matching/Digital Fingerprinting) : إنشاء بصمة رقمية فريدة للمستندات الحساسة (مثل العقود أو المخططات الهندسية). حتى إذا تم تغيير اسم الملف أو تعديل بعض النصوص، يظل النظام قادرًا على التعرف عليه.
- التعبيرات المنتظمة (Regex) : البحث عن أنماط محددة مثل $\{d\{4\}-\{d\{4\}-\{d\{4\}-\{d\{4\}$ لبطاقات الائتمان.
- تحليل الملفات المتداخلة (Nested Files) : فحص الملفات المضغوطة (ZIP) ، (RAR) أو المرفقات داخل المرفقات للتأكد من عدم إخفاء بيانات حساسة داخلها.
- التعرف الضوئي على الحروف (OCR) : قراءة النصوص داخل الصور (مثل لقطة شاشة تحتوي على بيانات مالية) والمستندات المسحوبة ضوئيًا.

2.9 إعادة بناء وتتبع الجلسات (Session Reconstruction & Tracking)

- لضمان دقة التحقيق في الحوادث الأمنية، يقوم نظام DLP المتقدم بإعادة بناء جلسات المستخدمين. بدلاً من رؤية حدث فردي (حدث سجل)، يقوم النظام بربط الأحداث معًا:
- تتبع الجلسة: ربط كل أنشطة المستخدم خلال فترة زمنية محددة (تسجيل الدخول، فتح مستند، نسخه، لصقه في بريد إلكتروني، إرساله).
 - السياق: فهم أن المستخدم قام بـ "نسخ" البيانات الحساسة من تطبيق محمي قبل ثوانٍ من "لصقها" في متصفح الويب الشخصي.
 - إعادة البناء: توفير واجهة للمسؤول تسمح له "بمشاهدة" تسجيل لجلسة المستخدم كأنه كان جالسًا أمامه، مما يسهل عملية التمييز بين الخطأ البشري والنية الخبيثة.

2.10 آليات الإنذار والاستجابة الفورية

عند اكتشاف انتهاك لسياسة DLP ، يقوم النظام بسلسلة من الإجراءات التلقائية:

1. الإنذار (Alerting) : إرسال تنبيه فوري إلى SOC (مركز العمليات الأمنية) عبر البريد الإلكتروني، أو SIEM ، أو لوحة التحكم.
2. الحظر (Block) : منع نقل البيانات نهائيًا مع عرض رسالة للمستخدم تفيد بانتهاك السياسة.
3. العزل (Quarantine) : عزل البريد الإلكتروني أو الملف في منطقة انتظار حتى يقوم المسؤول بمراجعته والموافقة عليه يدويًا.
4. التشفير (Encryption) : في بعض الحالات، إذا تم إرسال بيانات حساسة إلى شريك خارجي موثوق، يقوم النظام بتشفير البريد الإلكتروني تلقائيًا دون مقاطعة تدفق العمل.
5. التعليم (User Education) : عرض نافذة منبثقة للمستخدم تشرح له سبب المنع وكيفية التعامل الصحيح مع البيانات، مما يساهم في تغيير السلوك.

2.11 تصنيف البيانات (Data Classification)

تصنيف البيانات هو حجر الأساس لأي نظام DLP فعال. يتضمن العملية:

- المسح الضوئي (Discovery): تحديد مكان وجود البيانات الحساسة (على الخوادم، في السحابة، على أجهزة المستخدمين).
- الوسم (Labeling): إضافة علامات (ميتاداتا) للملفات مثل "سري"، "عام"، "شخصي". يمكن أن يتم هذا الوسم يدويًا بواسطة المستخدم، أو تلقائيًا بواسطة النظام بناءً على المحتوى.
- التصنيف الهرمي: بناء هيكل تصنيف يعكس حساسية البيانات (مثلاً: عام < داخلي < سري < سري للغاية). السياسات تطبق بناءً على هذا التصنيف.

2.12 تطبيق السياسات (Policy Enforcement)

هي مرحلة التنفيذ العملي. السياسة في DLP هي قاعدة منطقية تتكون من:

- الشرط (Condition): من (المستخدم)، ماذا (البيانات)، إلى أين (الوجهة)، كيف (التطبيق).
 - الإجراء (Action): مراقبة فقط، إنذار، حظر، تشذير، أو السماح مع التسجيل.
 - الاستثناءات (Exceptions): تعريف حالات يُسمح فيها بنقل البيانات رغم حساسيتها (مثل الإرسال إلى عنوان يريد إلكتروني معتمد لشريك تجاري).
- يتم نشر السياسات بشكل مركزي لضمان الاتساق في تطبيق الأمان عبر جميع نقاط النهاية والبوابات.

2.13 أحدث ما توصلت إليه التكنولوجيا State of the Art

في السنوات الأخيرة، تطورت أنظمة DLP بشكل كبير لتواكب التحديات الجديدة مثل العمل الهجين، التشفير الشامل، والذكاء الاصطناعي التوليدي (GenAI). لم تعد الحلول التقليدية المعتمدة على القواعد الثابتة (Signature-based) كافية.



رسم توضيحي 7: أعلى أنواع DLP في السوق حسب التسعير

أحدث الاتجاهات والتقنيات:

1. دمج الذكاء الاصطناعي (AI) والتعلم الآلي (ML):

- التصنيف السياقي الذكي :استخدام نماذج NLP (معالجة اللغة الطبيعية) لفهم معنى النص بدلاً من مجرد البحث عن كلمات مفتاحية. على سبيل المثال، التمييز بين "مصطلح طبي في مقالة علمية" و"بيانات مريض حساسة".
 - كشف الشذوذ السلوكي (UEBA - User and Entity Behavior Analytics) : بناء نموذج سلوكي لكل موظف. إذا قام موظف عادة بإرسال 5 ميجابايت يوميًا، ثم حاول فجأة إرسال 5 جيجابايت في الساعة الثالثة صباحًا، يقوم النظام بتصنيف هذا كسلوك عالي الخطورة حتى لو كانت البيانات غير مصنفة صراحةً على أنها حساسة.
 - 2. DLP في بيئة التشفير الشامل (TLS 1.3 / E2EE) :
 - مع صعوبة اعتراض حركة المرور المشفرة(HTTPS) ، انتقلت الحلول الحديثة إلى الاعتماد على API-based Integration مع تطبيقات السحابة) مثل (Microsoft 365 DLP, Google Workspace DLP بدلاً من محاولة فك التشفير على مستوى الشبكة.
 - 3. حماية البيانات في الذكاء الاصطناعي التوليدي (GenAI Security) :
 - ظهور جيل جديد من حلول DLP التي تركز على منع المهندسين والموظفين من لصق الكود المصدري أو البيانات الحساسة في أدوات مثل ChatGPT ، Copilot ، أو Gemini ، مع السماح باستخدامها بأمان (Shadow AI Discovery).
 - 4. دمج DLP مع XDR و SIEM :
 - التحول من حلول قائمة بذاتها (Standalone) إلى مكون أساسي في منصة Extended Detection and Response (XDR) حيث يتم ربط أحداث DLP مباشرةً مع أحداث نقطة النهاية والحوادث الأخرى لتقديم رؤية موحدة.
 - 5. حماية البيانات في السحابة المتعددة (Multi-Cloud DLP) :
 - حلول تعمل كطبقة تحكم فوق AWS, Azure, GCP ، تراقب تكوينات buckets مثل S3 لمنع التسريبات الناتجة عن أخطاء التكوين البشرية. (Misconfiguration)
- جدول مقارنة State of the Art :

المعيار	الجيل التقليدي (Traditional DLP)	الجيل الحديث (Next-Gen / State of the Art)
منهجية التحليل	قائم على القواعد / (Rules-based) التعبيرات المنتظمة (Regex)	قائم على الذكاء الاصطناعي (AI/ML) وفهم السياق (Contextual Awareness)
البيئة المستهدفة	مركزية / (On-Premises) حدود الشبكة (Perimeter)	سحابة أولاً (Cloud-first) , (Hybrid) موزعة أجهزة طرفية
معالجة التشفير	يعتمد على فك التشفير – (SSL Interception) صعب مع TLS 1.3	يعتمد على APIs ومصادر البيانات الأصلي (Native Integrations)

يربط بين السلوك والمحتوى والهوية	محدود (يركز على المحتوى فقط)	الكشف عن السلوك
استجابة آلية (SOAR) ، تثقيف المستخدم في الوقت الفعلي، تصحيح تلقائي	حظر/سماع بسيط	الاستجابة
دعم مدمج لتطبيقات SaaS و GenAI عبر APIs	غير مدعومة (مثل Slack ، Teams)	التطبيقات الجديدة

جدول 18: State of the Art

2.14 الدراسات المرجعية (Reference Studies)

لضمان صحة المتطلبات وفهم التحديات العملية، تم الرجوع إلى مجموعة من الأوراق الأكاديمية والتقارير الصناعية الرائدة. تم اختيار هذه الدراسات لتغطية الجوانب النظرية والتطبيقية لأنظمة DLP. أبرز الدراسات المرجعية:

1. Gartner, "Market Guide for Data Loss Prevention" -2022 , renewed 2024
 - المُلخَص: تعتبر المرجعية الأهم في الصناعة. تحدد الاتجاهات الحالية، تقدم مصفوفة تقييم للموردين، وتؤكد على أن DLP أصبح جزءاً من استراتيجية أوسع تسمى "Data Security Platforms (DSP)" بدلاً من كونه منتجاً منفرداً.
 - الخلاصة المستفادة: يجب أن يركز النظام المقترح على التكامل السلس مع بيئات السحابة (SaaS) ودعم سياسات موحدة عبر نقطة النهاية والشبكة.
2. 2020 - NIST Special Publication 800-175, "Guide to Data Loss Prevention" المعهد الوطني للمعايير والتقنية الأمريكي
 - المُلخَص: دراسة أكاديمية منهجية تقدم إطاراً نظرياً لتصنيف البيانات (Data Classification) وآليات تطبيق السياسات (Policy Enforcement) في المؤسسات الحكومية والخاصة.
 - الخلاصة المستفادة: وضع أساس متين لتصنيف البيانات (الفصل 2.11) وأهمية الفصل بين سياسات "المنع" و"المراقبة".
3. 2023 - SANS Institute, "Practical Implementation of DLP: Avoiding the Pitfalls"
 - المُلخَص: دراسة تطبيقية تركز على الأخطاء الشائعة أثناء تنفيذ DLP ، مثل "التنبيه المفرط (Alert Fatigue)" وتأثير الأداء على الأجهزة الطرفية. تقدم منهجية "التنفيذ التدريجي" بدءاً من وضع المراقبة (Monitor Mode) قبل وضع الحظر. (Block Mode)
 - الخلاصة المستفادة: ضرورة تصميم النظام ليعمل في وضع "التعلم" أولاً لتجنب تعطيل الأعمال (Business Disruption).
4. Forrester Wave™: Data Loss Prevention Suites - 2024

- الملخص: تقييم تحليلي مقارنة لأكبر مزودي حلول DLP في السوق (Microsoft, Broadcom, Trellix, etc.).
ركز التقرير على قدرات الحلول في التعامل مع "بيئة العمل الهجين" و"البيانات غير المنظمة (Unstructured Data)".
 - الخلاصة المستفادة: إثبات أن قدرة النظام على فحص المحتوى العميق (Deep Content Inspection) في الملفات غير المنظمة (PDF، CAD، Source Code) هي الفارق الأساسي بين الحلول المتوسطة والمتقدمة.
 - 5. ACM Computing Surveys, "A Survey on Data Leakage Prevention Systems" - 2021
 - الملخص: دراسة أكاديمية شاملة تستعرض الخوارزميات المستخدمة في اكتشاف التسريبات، مقارنة بين تقنيات الـ Fingerprinting والـ NLP من حيث الدقة (Accuracy) والإيجابيات الخاطئة (False Positives).
 - الخلاصة المستفادة: دعم اختيار تقنية الفحص الهجين (Hybrid Analysis) التي تجمع بين الـ Fingerprint للمستندات الثابتة والـ NLP للمراسلات النصية لتحقيق أعلى دقة.
- جدول مقارنة: الدراسات المرجعية

الدراسة	المصدر/ السنة	التركيز الرئيسي	القيمة المضافة للمشروع الحالي
Gartner Market Guide	Gartner, 2022-2024	استراتيجية السوق، تحليل البائعين، مستقبل DLP كجزء من DSP	تحديد ضرورة دعم Cloud APIs و Unified Policy Management في النظام.
NIST SP 800-175	2020, NIST	الإطار النظري، تصنيف البيانات، إدارة المخاطر	توفير نموذج صارم لتصنيف البيانات (Data Classification Matrix) وآليات التوثيق.
SANS Practical Implementation	SANS Institute, 2023	التطبيق العملي، تجنب الأخطاء، وضع "المراقبة"	اعتماد منهجية (Phased Rollout مراقبة -> محاكاة -> حظر) لتقليل الاحتكاك بالمستخدمين.
Forrester Wave: DLP Suites	Forrester, 2024	تقييم المنتجات التجارية، التعامل مع Unstructured Data	التركيز على ضرورة دعم Deep Content Inspection للملفات التقنية (CAD, Code) وليس فقط النصوص.
ACM Survey on DLP	ACM, 2021	خوارزميات الكشف (Fingerprinting, NLP, ML)، الدقة مقابل الإيجابيات الخاطئة	اختيار تقنية Hybrid Analysis لتحقيق توازن بين سرعة الفحص ودقة النتائج.

جدول 19 : الدراسات المرجعية

2.15 الخلاصة

من خلال الاستعراض التفصيلي للمفاهيم الأساسية والدراسات المرجعية، يتضح أن بناء نظام DLP فعال يتطلب أكثر من مجرد أداة تقنية. يتطلب النظام رؤية شاملة تبدأ من تصنيف دقيق للبيانات، مروراً بفهم عميق لحركة المرور على مختلف المستويات (الخوادم، المتصفحات، الأجهزة الطرفية)، وانتهاءً بآليات استجابة ذكية لا تعطل سير العمل.

أظهرت دراسة "State of the Art" أن الصناعة تتجه بسرعة نحو دمج الذكاء الاصطناعي وتحليل السلوك (UEBA) لمواجهة تحديات التشفير والعمل عن بُعد، بينما أكدت الدراسات المرجعية (Gartner, NIST, SANS) على أهمية التكامل مع البيئة السحابية واتباع منهجية تنفيذ تدريجية لضمان نجاح المشروع.

بناءً على هذه الأسس، سينتقل المشروع في الأقسام التالية إلى مرحلة التحليل والتصميم، حيث سيتم ترجمة هذه المفاهيم النظرية إلى متطلبات وظيفية (Functional Requirements) وهندسة معمارية (Architecture) محددة للنظام المقترح.